

Draft Statement of Work (SOW)

Cloud Center of Excellence (CCoE) Implementation Indian Health Service (IHS) Division of Information Technology (DIT)

1. INTRODUCTION

The Indian Health Service (IHS), an agency within the U.S. Department of Health and Human Services (HHS), is initiating a strategic modernization program to establish a Cloud Center of Excellence (CCoE). The CCoE will utilize Cloud (GovCloud - FedRAMP) to centralize, secure, and automate cloud operations while supporting mission-critical health IT objectives.

This Statement of Work (SOW) outlines the tasks, deliverables, roles, and performance expectations for designing, implementing, and sustaining the CCoE in alignment with federal compliance frameworks including:

- FedRAMP (High Baseline)
- NIST 800-53 Rev 5
- Executive Order 14028
- OMB M-22-09, M-24-04
- CISA's Zero Trust Maturity Model (ZTMM)
- Post Quantum Computing (PQC) Readiness meeting PQC Mandate Enablement
- Secure AI ready platform

2. BACKGROUND

IHS currently operates in a decentralized IT environment that contributes to fragmented infrastructure, inconsistent security enforcement, and risk exposure. GAO Report GAO-21-20 identified several deficiencies in cloud governance, visibility, and cybersecurity readiness.

To address these gaps, IHS will implement a secure Cloud GovCloud-based environment that consolidates infrastructure, automates security workflows, and incorporates role-based AI tools. The CCoE will enable continuous compliance, reduce operational overhead, and support innovation across IHS facilities.

3. SCOPE OF WORK

The Contractor shall provide a comprehensive solution that includes, but is not limited to, the following capabilities:

- **Cloud Landing Zone Design & Deployment**
 - Multi-account Cloud architecture with governance controls
 - Use of Cloud Control Tower, Service Catalog, and Cloud Organizations
 - Identity and access management aligned with Zero Trust principles
- **Secure Enclave Provisioning**
 - Configured enclaves for development, staging, and production workloads
 - FedRAMP-compliant storage, compute, and networking (e.g., EC2, S3, VPC, PrivateLink)
 - Hardened environments using CIS benchmarks and Cloud best practices
- **Automation and Orchestration**
 - Automated workflows for ATO lifecycle management
 - Continuous POA&M generation, patch validation, and compliance reporting
 - Integration with SIEM (e.g., Splunk), SOAR tools, and Cloud Security Hub
- **Data Engineering and ETL**
 - Extract-Transform-Load (ETL) pipelines for ingesting and transforming log and event data
 - Integration with Cloud native telemetry (e.g., CloudTrail, GuardDuty) and third-party tools
 - Masking and classification of PHI/PII in compliance with HIPAA and FISMA
- **Large Language Model (LLM) Enablement**
 - On-premise or enclave-deployed LLMs for secure, role-based inference
 - AI-assisted document generation (e.g., SSP, SAR, RAR, POA&M)
 - Local semantic search and summarization of compliance materials
 - Use of containerized, GPU-accelerated inference in isolated VPCs
- **Compliance Dashboards and Risk Analytics**
 - Real-time compliance status dashboards for executive reporting
 - Dashboards showing ATO progress, open vulnerabilities, audit readiness
 - Integration with natural language interfaces for querying compliance data
- **Zero Trust Architecture Implementation**
 - Aligned with CISA Zero Trust Maturity Model (ZTMM)
 - Support for microsegmentation, encrypted remote access, and continuous validation
 - Maturity benchmarking and optimization across all ZTA pillars
- **Security Operations and Monitoring**
 - Centralized log aggregation and threat detection via SIEM
 - Endpoint Detection and Response (EDR), vulnerability management
 - Continuous diagnostics and mitigation (CDM) support
- **Secure Data Vault and Metadata Governance**
 - Encrypted storage with tagging and classification aligned with NIST 800-60
 - Role-based tagging, automated metadata parsing, and retention policies
 - AI-assisted classification and redaction for secure document handling
- **Stakeholder Support and Role-Based Toolkits**
 - Interfaces and workflows tailored to ISSOs, POA&M Analysts, Auditors, System Owners
 - Embedded help systems and LLM-based support assistants
 - Training materials and job aids customized per role

4. OBJECTIVES

The objectives of the Cloud Center of Excellence (CCoE) initiative are to modernize, secure, and automate IHS cloud operations across the enterprise, in alignment with federal mandates, audit recommendations, and the agency's mission to improve healthcare delivery through digital transformation. This section outlines the business, technical, security, and strategic outcomes the initiative is expected to achieve.

4.1 Business Objectives

- Establish a centralized cloud governance model to address findings in GAO Report GAO-21-20 and reduce operational fragmentation.
- Enable secure, compliant testing and deployment of mission-critical applications through standardized Cloud environments.
- Implement a cost accountability framework via a chargeback model supported by Cloud Budgets and Cost Explorer.
- Reduce total cost of ownership through tool rationalization, license consolidation, and automation of manual compliance functions.
- Improve leadership visibility into risk posture, operational performance, and compliance status through real-time executive dashboards.

4.2 Technical Objectives

- Design and deploy a secure Cloud Landing Zone architecture with multi-account governance, VPC segmentation, and centralized identity and access management.
- Automate core compliance and operational workflows including:
 - ATO package generation
 - POA&M lifecycle tracking
 - Patch deployment validation
 - Security incident ticketing and audit response
- Integrate telemetry, logs, and vulnerability scan results into a unified SIEM and dashboarding platform.
- Establish secure ETL pipelines from Cloud and third-party telemetry sources into centralized compliance dashboards and data lakes.
- Deploy GPU-enabled container environments for operating fine-tuned, enclave-hosted LLMs in support of documentation generation, compliance analytics, and secure information retrieval.

4.3 Security and Compliance Objectives

- Achieve continuous compliance monitoring and FedRAMP alignment across deployed systems and workflows.
- Implement Zero Trust Architecture (ZTA) principles throughout the environment in accordance with CISA's ZTMM framework.

- Provide role-specific support tools for ISSOs, Security Control Assessors, POA&M Analysts, and System Owners, enhancing their efficiency and audit-readiness.
- Enable enclave-based LLMs to support automated generation of SSPs, SARs, SAPs, and other required documentation with no data egress.
- Monitor compliance posture in real-time through dashboards that provide insights into ATO progression, vulnerability resolution, patch coverage, and audit gaps.

4.4 Strategic Outcomes

- Empower IHS leadership with defensible, data-driven insights into cybersecurity, operations, and cloud utilization.
- Institutionalize a scalable, repeatable cloud operations model that supports future IHS initiatives, including EHR modernization and AI-driven analytics.
- Reduce the burden on IHS security and compliance staff by automating routine workflows and documentation tasks using enclave-secured LLMs.
- Increase IHS agility in adopting and securing commercial-off-the-shelf (COTS) tools by establishing pre-authorization environments.
- Create a foundation for continual innovation by deploying cloud-native and AI-native technologies in a secure and governed manner.

5. PERIOD OF PERFORMANCE

One Year. All core implementation phases (enclave setup, automations, training) are to be completed within the Base Year.

6. PLACE OF PERFORMANCE

All work shall be performed remotely unless otherwise directed by the Contracting Officer. The Contractor shall use IHS-approved virtual collaboration platforms for meetings, training, and reviews.

7. PHASED IMPLEMENTATION PLAN & DELIVERABLES

The CCoE shall be delivered in three integrated phases. Each phase builds on the previous to ensure secure design, operational automation, and sustainable cloud governance. All activities will comply with IHS, HHS, and federal cybersecurity mandates.

7.1 Phase 1: Foundation — Secure Enclave and Cloud Infrastructure Deployment

Objective:

Establish the secure Cloud GovCloud infrastructure, deploy baseline logging, identity, and ETL capabilities, and prepare for authorization under FedRAMP and IHS-specific requirements.

Key Activities:

- Deploy Cloud Landing Zone using Cloud Control Tower and multi-account best practices
- Configure core services: EC2, S3 (Standard, Glacier IR, Deep Archive), IAM, VPC, and PrivateLink
- Enable centralized logging, auditing, and threat detection with Cloud CloudTrail, GuardDuty, and Config
- Provision ETL servers and data pipelines to Splunk/Data Lake
- Deploy GPU-enabled container environments for local LLMs in isolated VPCs
- Draft core ATO documentation including SSP, SAP, RAR, and ConMon strategy
- Establish compliance governance alignment with NIST, ZTMM, and FedRAMP High

Deliverables:

- Cloud Landing Zone Architecture and Configuration Artifacts
- IAM and VPC Security Configuration Documentation
- Hardened ETL Server Deployment Package and Logging Setup
- Baseline Data Classification and Masking Policy
- Initial LLM Hosting Blueprint with Secure Container Deployment
- Draft ATO Documents: SSP, SAP, RAR, Continuous Monitoring Strategy
- Cloud Governance and Risk Register (Initial Baseline)

7.2 Phase 2: Automation — Compliance, Risk Visibility, and ATO Enablement

Objective:

Automate security workflows, compliance operations, and risk analytics; integrate dashboarding, vulnerability scanning, and AI-powered documentation assistance.

Key Activities:

- Configure automation engines for POA&M tracking, ATO artifact generation, and patch lifecycle management
- Integrate Cloud Security Hub, SIEM, SOAR, and ticketing systems (e.g., ServiceNow)
- Deploy real-time dashboards for ATO progression, risk indicators, and vulnerability metrics
- Train enclave-hosted LLMs on redacted historical data for audit RFI generation, SSP/POA&M summarization, and classification
- Conduct full UAT with compliance and security teams across workflows and dashboards
- Finalize all ATO documentation for formal submission
- Document governance procedures for automation use and LLM assistance

Deliverables:

- Validated Automation Playbooks for ATO, POA&M, Patch, and IR workflows
- Deployed Compliance Dashboards with Export/Reporting Capabilities
- Integrated SIEM/EDR/Vulnerability Dashboard and Alerting Interfaces
- Enclave-Based LLM Toolkits: Prompt Libraries, Summary Engines, Audit RFI Generator
- Peer-Reviewed Codebase and QA Documentation for Security Automations
- Completed ATO Package: SSP, SAP, SAR, POA&M Workbook
- UAT Report, Change Logs, and Final QA Sign-off

7.3 Phase 3: Transition — Training, Knowledge Transfer, and Operational Readiness

Objective:

Ensure IHS personnel are fully equipped to operate, sustain, and enhance the CCoE platform through structured training, documentation, and role-specific toolkits.

Key Activities:

- Deliver role-specific training for ISSOs, System Owners, Engineers, Analysts, and Auditors
- Provide instructional resources: slide decks, recordings, quick-reference guides
- Conduct operational exercises in staging environments to validate training comprehension
- Finalize SOPs for Cloud, ETL, automation workflows, and LLM-based compliance tooling
- Complete knowledge transfer and governance handoff with defined ownership and escalation paths
- Deliver final project documentation package and operational readiness checklist

Deliverables:

- Training Curriculum by Role (ISSOs, DevSecOps, Security Analysts, etc.)
- Admin Manuals, Reference Guides, and Recorded Training Sessions
- SOPs for Enclave Management, ETL, Compliance Automation, and LLM Use
- Knowledge Transfer Package with Architecture, Workflows, and Configuration Artifacts
- Operational Readiness Checklist and Transition Acceptance Memo
- Final Compliance Snapshot Report (ZTMM, NIST 800-53, FedRAMP metrics)
- Post-Implementation Sustainability and Improvement Plan

8. KEY PERSONNEL AND RESPONSIBILITIES

The Contractor shall provide the following Key Personnel, each of whom must possess demonstrated experience supporting U.S. public sector cloud security, automation, and compliance modernization initiatives. All proposed personnel must be fully cleared to the Public Trust level or higher and shall remain assigned throughout the performance period unless

otherwise approved by the Contracting Officer (CO) and Contracting Officer's Representative (COR).

9. CONTRACT LINE ITEM NUMBERS (CLINs) & MILESTONES

CLIN Structure

- **CLIN 001** – Architecture & Deployment (Landing Zone, Enclave, Infrastructure)
- **CLIN 002** – Automation Integration & Dashboarding
- **CLIN 003** – LLM Licensing & Container Deployment
- **CLIN 004** – Training & Transition Support
- **CLIN 005** – Embedded Resident Architect Support (optional, T&M)

CLIN	Description	Mapped Deliverables	Aligned Milestones
CLIN 001	Architecture, Landing Zone, and Secure Enclave Deployment	Cloud Landing Zone artifacts, IAM/VPC setup, Logging/Monitoring stack, ATO Drafts	M1, M2, M3
CLIN 002	Compliance Automation & Workflow Integration	Automation playbooks, POA&M engine, SIEM integration, ticketing flows	M4, M5, M6
CLIN 003	LLM Licensing, Secure Hosting, and Toolkits	LLM deployment containers, prompt libraries, audit RFI generator, classification engine	M4, M5, M6
CLIN 004	Training, SOPs, and Knowledge Transfer	Role-based training materials, recorded sessions, SOPs, transition plan	M7, M8

Milestone Schedule

This milestone table defines major delivery checkpoints across the three phases. Each milestone includes a brief description, expected deliverables, and target completion timeline (based on award date). This format is aligned with IHS procurement expectations.

Milestone	Description	Key Deliverables	Target Date
M1 – Project Kickoff	Formal launch of contract; finalization of schedule, roles, access, and governance	Kickoff Briefing, WBS, Master Project Plan	Within 10 business days of award
M2 – Secure Enclave Deployment	Completion of Cloud Landing Zone and baseline security infrastructure	Cloud Architecture Docs, ETL Servers, IAM/VPC Configs	End of Month 2

Milestone	Description	Key Deliverables	Target Date
M3 – Draft ATO Package Submitted	Submission of draft ATO documents for internal review and updates	SSP, SAP, RAR, ConMon, Risk Register	End of Month 3
M4 – LLM Integration (Phase 1)	Initial deployment of LLMs in secure containers, focused on documentation and classification	LLM Hosting Plan, Redacted Prompt Templates, SSP Draft Generator	End of Month 4
M5 – Automation Engine Operational	Compliance workflows (ATO, POA&M, IR) operational with integrations and dashboards	Playbooks, Codebase, SIEM Integration, POA&M Tracker	End of Month 5
M6 – UAT and ATO Package Finalized	Completion of UAT for all dashboards, automations, and workflows; submission-ready ATO	Final ATO Package, UAT Report, QA Logs	End of Month 6
M7 – Training and Transition Execution	Training delivered across stakeholder roles, with documentation and environment access	Training Completion Report, SOPs, Admin Guides	End of Month 7
M8 – Operational Readiness Certification	Governance transition to IHS team, validation of full capability and compliance	Final Architecture Bundle, OR Checklist, Governance Plan	End of Month 8
M9 – Post-Transition Support (Optional)	Periodic support, tuning, or incident response assistance as required by IHS	Support Logs, Performance Reports, Improvement Proposals	Months 9–12 (optional CLIN use)

10. SECURITY, PRIVACY, AND COMPLIANCE REQUIREMENTS

All work must comply with the following:

- **Data Sovereignty:** All data remains in Cloud GovCloud (US), including LLM operations.
- **Standards:**
 - FedRAMP High
 - NIST 800-53 Rev 5
 - CISA Zero Trust Maturity Model (ZTMM)
 - EO 14028, OMB M-22-09, M-24-04
- **Personnel:** Public Trust background clearance required.
- **Non-Disclosure:** NDAs required for all Contractor personnel accessing sensitive IHS data.

11. PERFORMANCE METRICS AND REPORTING

Performance will be evaluated based on:

- Timeliness of deliverables (± 10 business days)
- Accuracy and usability of ATO documentation
- Compliance of enclave with security benchmarks
- Training satisfaction scores ($\geq 90\%$ competency pass)
- Risk dashboards maintained with ≤ 24 hr lag from telemetry source

Reporting Requirements

- **Weekly:** Status updates, risk registers, and action items
- **Monthly:** Executive dashboards and cost transparency reports
- **Quarterly:** Performance and compliance reviews with stakeholders